

4.5 Record: top ten by CVSS

Rank	Finding ID	Host	CVSS	Vulnerability	Suspicious? Why?
1	MTB-0001	MTB-WEB01	9.8	Apache HTTP Server Path Traversal and RCE Apache httpd 2.4.49	Yes. CVE-2021-42013 applies to Apache 2.4.50, but the scanner detected 2.4.49. Version 2.4.49 is associated with CVE-2021-41773 instead.
2	MTB-0009	MTB-APP01	9.8	vsftpd Backdoor Command Execution vsftpd 2.3.4	Possibly. Only a compromised distribution of vsftpd 2.3.4 contained the backdoor, so the version banner alone does not prove this installation is backdoored.
3	MTB-0012	MTB-APP01	9.8	GNU Bash Shellshock Remote Code Execution GNU bash 5.1.16	Yes. Shellshock is a vulnerability from 2014, while the detected Bash 5.1.16 is a much newer release and should already contain the fix.
4	MTB-0016	MTB-FILE01	9.8	Samba is_known_pipename RCE (SambaCry) Samba 4.15.13	Yes. SambaCry affected older Samba releases, while the detected Samba 4.15.13 is newer than the patched versions.
5	MTB-0024	MTB-DC01	9.8	Remote Desktop Services RCE (BlueKeep) Windows Server 2019	Yes. BlueKeep affected older Windows versions such as Windows Server 2008, not Windows Server 2019
6	MTB-0031	MTB-DVWA01	9.8	SQL Injection in Application Parameter Apache 2.4.52 / PHP 8.1	No obvious mismatch. DVWA is intentionally vulnerable, so SQL injection in an application parameter is believable and should be tested.
7	MTB-0025	MTB-DC01	8.8	Netlogon Elevation of Privilege (ZeroLogon) Windows Server 2019	Not obviously suspicious. Windows Server 2019 can be affected by ZeroLogon. If the necessary security updates and enforcement changes are missing. Patch status must be checked.
8	MTB-0032	MTB-DVWA01	8.8	OS Command Injection in Application Parameter Apache 2.4.52 / PHP 8.1	No obvious mismatch. Command injection is a known intentional weakness in DVWA, but the affected parameter should still be tested.

Rank	Finding ID	Host	CVSS	Vulnerability	Suspicious? Why?
9	MTB-0018	MTB-FILE01	8.1	SMB Signing Not Required Samba 4.15.13	No obvious mismatch. SMB signing is controlled through configuration, so Samba 4.15.13 could still be configured not to require it.
10	MTB-0003	MTB-WEB01	7.8	polkit pkexec Local Privilege Escalation (PwnKit) policykit-1 0.105-31	Possibly. PwnKit affected older polkit installations, but Linux vendors sometimes backport patches without changing the main version number. The package's full revision and patch status need verification.

5.6 Record: validated findings

Finding ID	CVE	Detected version	Affected range (from NVD)	Verdict	Evidence and reasoning
MTB-0001	CVE-2021-42013	Apache httpd 2.4.49	Apache HTTP Server 2.4.49 and 2.4.50	True positive	NVD states that CVE-2021-42013 affects Apache HTTP Server 2.4.49 and 2.4.50. MTB-WEB01 runs Apache 2.4.49, which falls within the affected versions. The evidence also shows CGI is enabled, so the RCE conditions may be present.
MTB-0012	CVE-2014-6271	GNU Bash 5.1.16	GNU Bash versions through 4.3	False positive	NVD states that CVE-2014-6271 affects GNU Bash through version 4.3. MTB-APP01 runs GNU Bash 5.1.16, which is newer than the affected range. Therefore, the detected version is not vulnerable to this CVE, and the scanner finding is a false positive.
MTB-0016	CVE-2017-7494	Samba 4.15.13	Samba 3.5.0 through versions before 4.4.14, 4.5.10, and 4.6.4	False positive	NVD states that CVE-2017-7494 affects Samba beginning with version 3.5.0 and versions before the patched releases 4.4.14, 4.5.10, and 4.6.4. MTB-FILE01 runs Samba 4.15.13, which is far newer than the affected versions.

Finding ID	CVE	Detected version	Affected range (from NVD)	Verdict	Evidence and reasoning
					Therefore, the scanner finding is a false positive.
MTB-0024	CVE-2019-0708	Windows Server 2019	Windows 7 SP1, Windows Server 2008 SP2, and Windows Server 2008 R2 SP1	False positive	NVD states that CVE-2019-0708 affects Windows 7 SP1, Windows Server 2008 SP2, and Windows Server 2008 R2 SP1. MTB-DC01 runs Windows Server 2019, which is a newer operating-system generation outside the affected versions. Therefore, the scanner finding is a false positive.
MTB-0025	CVE-2020-1472	Windows Server 2019	Windows Server 2008 R2 SP1, 2012, 2012 R2, 2016, and 2019 domain controllers without the required security update	True positive	CVE-2020-1472 affects Windows Server 2019 domain controllers. MTB-DC01 runs Windows Server 2019, and its last cumulative update was installed on June 9, 2020. Microsoft's fix was released on August 11, 2020, so the server does not have the required update and the finding is a true positive.

6.3 The ten CVEs in this assessment

CVE	CVSS	In KEV?	Date added	Ransomware ?	Your priority notes
CVE-2021-42013	9.8	Yes	2021-11-03	Known	Highest priority because it is a true positive, appears in KEV, has known ransomware use, and could allow remote code execution on the web server.
CVE-2021-41773	7.5	Yes	2021-11-03	Known	High priority because the detected Apache version is affected, it appears in KEV, and it has known ransomware use.
CVE-2021-4034	7.8	Yes	2022-06-27	Known	High priority because it affects two hosts, appears in KEV, has known ransomware use, and could allow local privilege escalation.
CVE-2020-11022	6.1	No	N/a	N/a	Lower priority because it is not listed in KEV and has no confirmed exploitation

CVE	CVSS	In KEV?	Date added	Ransomware ?	Your priority notes
					recorded there, although the affected jQuery version should still be updated.
CVE-2011-2523	9.8	No	N/a	N/a	Requires additional verification. NVD states that only vsftpd 2.3.4 copies downloaded between June 30 and July 3, 2011 contained the backdoor, so the version banner alone does not confirm that this installation is vulnerable. It is not listed in KEV.
CVE-2014-6271	9.8	Yes	2022-01-28	Unknown	Remove from the remediation list because it is a false positive on this host. It appears in KEV, but the installed Bash version is not affected.
CVE-2017-7494	9.8	Yes	2023-03-30	Known	Remove from the remediation list because it is a false positive on this host. It appears in KEV and has known ransomware use, but the installed Samba version is not affected.
CVE-2023-4911	6.5	Yes	2023-11-21	Unknown	NVD lists upstream glibc versions 2.34 through versions before 2.39 as affected, which includes the detected 2.35 version. However, the full Ubuntu package revision must be checked to determine whether a security fix was backported.
CVE-2019-0708	9.8	Yes	2021-11-03	Known	Remove from the remediation list because it is a false positive on this host. BlueKeep appears in KEV and has known ransomware use, but Windows Server 2019 is not affected.
CVE-2020-1472	8.8	Yes	2021-11-03	Known	Very high priority because it is a true positive on the domain controller, appears in KEV, has known ransomware use, and the server predates the required security update.

6.5 Record: re-prioritised findings

New rank	Finding ID	Host	CVSS	In KEV	Why it sits here
1	MTB-0001	MTB-WEB01	9.8	Yes	Critical remote-code-execution finding affecting the web server, with confirmed exploitation and known ransomware use.
2	MTB-0025	MTB-DC01	8.8	Yes	Zerologon affects an unpatched domain controller, has confirmed exploitation, and has known ransomware use.

New rank	Finding ID	Host	CVSS	In KEV	Why it sits here
3	MTB-0003	MTB-WEB01	7.8	Yes	PwnKit has confirmed exploitation and known ransomware use and could provide elevated privileges on the web server.
4	MTB-0019	MTB-FILE01	7.8	Yes	PwnKit also affects the file server, creating an actively exploited privilege-escalation risk.
5	MTB-0002	MTB-WEB01	7.5	Yes	The affected Apache version is running on the web server, and the vulnerability has confirmed exploitation and known ransomware use.
6	MTB-0014	MTB-APP01	6.5	Yes	Ranks above non-KEV findings because NVD places upstream glibc 2.35 within the affected range and the CVE is in KEV, although the Ubuntu package revision should be verified for a backported fix.
7	MTB-0009	MTB-APP01	9.8	No	Ranks below the KEV findings because it is not in KEV and the 2.3.4 banner alone does not prove that this is the compromised build. Additional verification is required.
8	MTB-0004	MTB-WEB01	6.1	No	It is not listed in KEV and has the lowest CVSS score among the remaining validated CVE findings.

7.3 Report

Section	Contents
Executive summary	The assessment identified several security weaknesses that could allow an attacker to compromise the public web server, gain administrative access to internal systems, or take control of the organization's windows network. The most urgent findings have already been used in real attacks, so they should be corrected immediately, beginning with the web server and domain controller. Three scanner alerts were proven to be false and were removed, allowing resources to remain focused on genuine risks. Temporary safeguards should be applied wherever an immediate update is not possible, followed by regular scanning to confirm that fixes remain effective.
Scope and method	This vulnerability assessment covered five systems: MTB-WEB01, MTB-APP01, MTB-FILE01, MTB-DC01, and MTB-DVWA01. The scan evaluated operating systems, installed software, network services, application vulnerabilities, and security configurations. Findings were validated by comparing detected software versions and host evidence against the affected version ranges published by the National Vulnerability Database. Validated findings were then cross-referenced with CISA's Known Exploited Vulnerabilities catalog to prioritize vulnerabilities with confirmed real-world exploitation over findings ranked only by severity.
Prioritised findings	1. MTB-0001 – MTB-WEB01: Apache 2.4.49 and the enabled CGI configuration confirm exposure to CVE-2021-42013. Upgrade Apache to 2.4.51 or later; this ranks first because it is a Critical, KEV-listed RCE with known ransomware use. 2. MTB-0025 – MTB-DC01: Windows Server 2019 is affected by Zerologon, and its last update predates Microsoft's August 11, 2020 fix. Install the latest cumulative update and enforce secure Netlogon RPC; it ranks second because compromise could expose the entire domain. 3. MTB-0003 – MTB-WEB01: The detected policykit-1 version is affected by PwnKit. Update policykit-1 through Ubuntu's security repository; it ranks highly because it is KEV-listed, has known ransomware use, and could provide administrative privileges.

Section	Contents
	4. MTB-0019 – MTB-FILE01: The file server runs the same vulnerable policykit-1 version. Apply the PwnKit security update; it ranks highly because exploitation could provide administrative access to shared organizational files. 5. MTB-0002 – MTB-WEB01: Apache 2.4.49 is affected by CVE-2021-41773. Upgrade Apache to 2.4.51 or later; its KEV status, known ransomware use, and web-server exposure outweigh its lower CVSS score. 6. MTB-0014 – MTB-APP01: NVD lists upstream glibc versions 2.34 through versions before 2.39 as affected, which includes the detected 2.35 version. Confirm whether the installed Ubuntu package contains the vendor’s backported fix and update it through the approved Ubuntu security repository if necessary. Its KEV status gives it priority, but package-level validation is required before remediation. 7. MTB-0009 – MTB-APP01: The FTP service reports vsftpd 2.3.4, but NVD states that only copies downloaded between June 30 and July 3, 2011 contained the backdoor. Verify the package source, file hash, and whether port 6200 is exposed; if the compromised build is confirmed, remove it immediately and migrate to SFTP. It ranks below the KEV findings because it is not in KEV and has not yet been conclusively validated. 8. MTB-0004 – MTB-WEB01: jQuery 3.4.1 is affected by CVE-2020-11022. Upgrade to jQuery 3.5.0 or later; it ranks last because it is not in KEV and has the lowest CVSS score among the remaining CVE findings.
False positives	1. MTB-0012 – Shellshock: The scanner reported that GNU Bash 5.1.16 was vulnerable to CVE-2014-6271. NVD identifies Bash versions through 4.3 as affected, so the installed 5.1.16 version falls outside the affected range and the finding is a false positive. 2. MTB-0016 – SambaCry: The scanner reported CVE-2017-7494 on Samba 4.15.13. The vulnerability affects older Samba branches before the patched 4.4.14, 4.5.10, and 4.6.4 releases, making the installed 4.15.13 version unaffected. 3. MTB-0024 – BlueKeep: The scanner reported CVE-2019-0708 on Windows Server 2019. BlueKeep affects older systems, including Windows Server 2008 and 2008 R2, while Windows Server 2019 is outside the affected operating-system range. All three vulnerabilities appear in KEV, but they were removed from this remediation plan because the software installed on these particular hosts is not vulnerable. This demonstrates why findings must be validated before CVSS and threat-intelligence data are used for prioritization.
Compensating controls	No specific remediation delays were identified in the provided evidence. If immediate patching is not possible, the following temporary controls will remain in place until permanent remediation is completed: For the Apache vulnerabilities, disable unnecessary CGI functionality, configure “Require all denied,” and use the web application firewall to block

Section	Contents
	path-traversal attempts. Owner: Web Infrastructure Team Lead. Target date: September 11, 2026. • For Zerologon, restrict SMB, RPC, and Netlogon traffic to authorized internal systems and monitor Netlogon events for vulnerable connections. Owner: Active Directory Team Lead. Target date: September 11, 2026. • For PwnKit, temporarily remove the SUID permission from /usr/bin/pkexec, restrict shell access, and monitor unexpected privileged activity. Owner: Linux Infrastructure Team Lead. Target date: September 12, 2026. • For vsftpd, block external FTP access, restrict connections to approved source addresses, and monitor authentication and file transfers until migration to SFTP is complete. Owner: Application Server Team Lead. Target date: September 16, 2026. These controls are temporary and must be removed or reviewed after the permanent fixes have been tested and installed.
Recommended cadence	MTB-WEB01 should be scanned weekly and after every significant application or configuration change because it is a public-facing system with greater exposure to external attacks. MTB-DC01 should also receive weekly authenticated scans because compromise of the domain controller could affect the entire organization. MTB-APP01 should be scanned every two weeks, while MTB-FILE01 should be scanned monthly and after major configuration changes. MTB-DVWA01 may be scanned quarterly because it is an intentionally vulnerable, isolated testing system, but its network isolation should be verified monthly. A complete authenticated vulnerability assessment should also be performed quarterly across the environment. Follow-up scans should be conducted after remediation to confirm that vulnerabilities were successfully removed and that closed findings have not returned. This schedule prioritizes high-risk and frequently changing systems while maintaining consistent coverage of the entire environment.

8.5

1. Record exactly what triggered the alert: the process, the connection, and the behaviour that was flagged. Quote the alert.

The alert was triggered because MTB-WEB01 established an “outbound TCP session to 185.220.101.47 on port 8443 at a consistent 5 minute interval” even though the destination was not on an approved egress allowlist. The alert also identified “a root-owned process named ‘apache-worker’” that was not included in the bank’s standard Apache build. The combination of an unauthorized root-owned process and regular outbound connections suggested command-and-control beaconing.

2. Working from the five captures, write down the host's state at the time of capture: what was running, what it was connected to, and who was logged in.

At the time of capture, the host was running its normal Apache, SSH, and cron services, along with a suspicious root-owned Bash process executing /usr/local/bin/apache-worker as PID 1244. A sleep 300 child process supported the observed five-minute execution interval. The malicious process had an established connection from MTB-WEB01 to 185.220.101.47 on port 8443, while a separate legitimate SSH connection linked mtbadmin to internal address

10.50.1.31. The mtbadmin account was currently logged in, and login history showed an earlier unauthorized root session from 185.220.101.47.

3. List every indicator of compromise visible so far - process names, IP addresses, ports, file paths, account names. Use CyberChef for the addresses.

The visible indicators of compromise were the process apache-worker with PID 1244, its sleep 300 child process, external IP address 185.220.101.47, destination port 8443, file path /usr/local/bin/apache-worker, account root, and the cron entry that executed the file as root every five minutes. Port 22 was also relevant because the suspicious external address was previously used for a root SSH login. CyberChef extracted 0.0.0.0, 10.50.1.31, 10.50.2.24, and 185.220.101.47; however, the first three represented a listening address, the legitimate administrator's internal address, and MTB-WEB01's own address rather than malicious indicators.

4. Find the one login in Capture 3 that should not be there, and say what makes it stand out. Compare its source address against everything else in the captures.

The unauthorized login was the root session from 185.220.101.47 between 02:24 and 02:44 UTC. It stands out because it was a direct privileged login from an external address, unlike the legitimate mtbadmin session from internal address 10.50.1.31. The same external address was later connected to the unauthorized apache-worker process on port 8443, directly linking the login to the suspicious outbound activity.

5. Document your evidence-handling steps in the order they were performed, and explain why volatile data was captured before anything else. Reference the volatility table in Section 8.2.

MTB-WEB01 was isolated through a network access-control rule at 10:05 UTC but was intentionally left powered on. Investigators recorded running processes at 10:12:41, network connections at 10:13:02, logged-in users and login history at 10:13:20, open network files at 10:13:44, and scheduled tasks at 10:14:05. The disk was imaged afterward at 10:31 UTC. This order followed the volatility table because network connections and running system information can disappear within seconds or be permanently lost when a host is rebooted or powered off, while disk evidence remains available longer. Each command and collection time was documented because evidence collection itself makes small changes to the live system.

8.6 Record

Type	Value	Where you saw it	Why it is suspicious
Process	apache-worker (PID 1244)	Alert and Captures 1, 2, and 4	Root-owned process not included in the approved Apache build; connected to the suspicious external address.
IP address	185.220.101.47	Alert and Captures 2, 3, and 4	Non-allowlisted external address connected to the malicious process and used for an unauthorized root login.
Port	8443/tcp	Alert and Captures 2 and 4	Used for repeated outbound connections every five minutes to the suspicious external address.
File path	/usr/local/bin/apache-worker	Captures 1 and 5	Unauthorized executable disguised as an Apache component and running with root privileges.
Account	root	Capture 3	A remote root login originated from the same suspicious external address and remained active for 20 minutes.

Type	Value	Where you saw it	Why it is suspicious
Scheduled task	<code>* /5 * * * * root /usr/local/bin/apache-Worker >/dev/null 2>&1</code>	Capture 5	Runs the malicious script as root every five minutes, creating persistence and matching the alert's connection interval.

10.4

- Two files were created 27 seconds apart at 02:25:57 and 02:26:30. Explain what those two together accomplish that neither achieves alone.

`/usr/local/bin/apache-worker` is the malicious payload, while `/etc/cron.d/apache-logrotate` runs that payload as root every five minutes. The payload performs the malicious activity, and the scheduled task provides persistence by repeatedly restarting it; the payload alone might stop running, while the scheduled task alone would have nothing malicious to execute.

- Look at the two entries at 02:41:19 and 02:41:22. One file has content, the other is zero bytes. Explain what the attacker was doing and why one attempt worked while the other did not.

The attacker appears to have attempted to erase command-history evidence for both accounts. The `mtbadmin` history file is zero bytes, showing that it was successfully emptied, while the `root` history file still contains 465 bytes because the active root shell likely wrote its command history back to the file when the session ended.

- Compare the incident window against the baseline in Section 10.2. Write two sentences on what makes the incident activity obviously abnormal for this host.

The baseline shows routine system installation, configuration, logging, and business-file activity, with no unexpected accounts, executable files, SSH keys, or scheduled tasks being created. In contrast, the incident window contains a concentrated sequence of overnight changes that created a web payload, unauthorized account access, privileged SSH keys, a disguised executable, persistence, and attempted evidence removal.

11.7 Record: consolidated IOC list

Type	Indicator (defanged)	Source	What it detects
Network	185[.]220[.]101[.]47	Alert, access log, authentication log, and volatile captures	External attacker address used for exploitation, unauthorized root access, and command-and-control traffic.
Network	185[.]220[.]101[.]47:8443	Alert and network captures	Command-and-control endpoint contacted every five minutes by <code>apache-worker</code> .
File path	<code>/var/www/html/uploads/style.php</code>	File-system timeline and recovered files	Uploaded PHP web shell used to execute commands through web requests.
File path	<code>/usr/local/bin/apache-worker</code>	Process capture, timeline, shell history, and acquisition record	Disguised malicious payload responsible for outbound beaconing.
File hash	2dfc22e2fb93187b7537d9ffec52ecc94fd6416c84b78e68ff7a025e975c20c	Acquisition record	Exact SHA-256 fingerprint of <code>style.php</code> .

Type	Indicator (defanged)	Source	What it detects
File hash	1ebcce99569f4337f9ee3746b7b095a9f54abfe3036ef06014b1a00ea4d15d4b	Acquisition record	Exact SHA-256 fingerprint of apache-worker.
File hash	d9bc0ee387921dcaedfc87de4a72ec42e45cf268adb2777d5b014375417cb9cc	Acquisition record	Exact SHA-256 fingerprint of the malicious cron file.
File hash	0243860670744531f70b46cfb844a66eb8ca0de0e4b7b15dff991b3960577295	Acquisition record	SHA-256 fingerprint of the altered /etc/passwd file.
Account	svc-backup with UID 0	Authentication log, timeline, and root shell history	Unauthorized account with privileges equivalent to root.
Persistence	/etc/cron.d/apache-logrotate	Timeline, cron capture, system log, and shell history	Scheduled task that runs apache-worker as root every five minutes.
Other	SSH key labeled attacker@blackfin	Recovered /root/.ssh/authorized_keys	Unauthorized SSH key providing persistent root access.

11.8 Step by step

1. Correlate the host's local logs against the monitoring alert timeline in Section 8.1. Confirm the sequence of events lines up, and note anything that does not.

The local logs align with the monitoring alert. Reconnaissance began at 02:08 UTC, followed by successful path traversal at 02:12, remote command execution at 02:13, creation of the PHP web shell at 02:15, privilege escalation at 02:20, creation of a UID 0 backdoor account at 02:23, and an unauthorized root login at 02:24. The attacker then created apache-worker at 02:25 and its cron task at 02:26, after which the system log shows it running every five minutes beginning at 02:30. This matches the alert's report of periodic outbound connections beginning at approximately 02:31. The one-minute difference is not a meaningful conflict because the process had to start before establishing its outbound connection.

2. Trace the suspicious process and network activity from Section 8.3 back through the logs. What was it connecting to, when did it start, and what caused it to start?

The suspicious apache-worker process connected from MTB-WEB01 to 185.220.101.47 on TCP port 8443. The attacker created the executable at 02:25:57 and created its cron task at 02:26:30. Cron loaded the new task at 02:26:31 and first executed it as root at 02:30:01, followed by additional executions every five minutes. Therefore, the scheduled cron task caused the process to start and maintain the periodic outbound connection identified by the alert.

3. Establish how the attacker moved from the web server's unprivileged account to root. Name the mechanism and cite the exact log lines.

The attacker escalated from the unprivileged www-data web-server account to root by exploiting the PwnKit vulnerability in pkexec, corresponding to validated finding MTB-0003. At 02:20:47, the authentication log states that pkexec opened a session for root(uid=0) on behalf of uid=33, which is the www-data account. At 02:21:05, the log

confirms www-data: Executing command [USER=root] with [COMMAND=/bin/sh]. These entries show that code originally running through the web server obtained a root shell.

4. Identify every persistence mechanism the attacker installed. There are three distinct ones. Each would survive something different - a reboot, a password reset, a process being killed. Say which survives what.

The attacker installed three persistence mechanisms. First, the svc-backup account was created with UID 0, giving it root-equivalent privileges and allowing access to survive a reboot or a change to the legitimate root password. Second, an attacker-controlled public key labeled attacker@blackfin was added to /root/.ssh/authorized_keys, allowing passwordless root access that would survive both a reboot and a password reset. Third, /etc/cron.d/apache-logrotate was created to execute /usr/local/bin/apache-worker as root every five minutes; this survives a reboot and restarts the payload if its running process is killed. The svc-backup account also had an authorized key configured, strengthening the attacker's alternate-access mechanism.

12. Day 3, Part 5: Root Cause and Forensic Report

12.1 Finding the root cause

Root cause is not the webshell, and it is not the beacon. Those are consequences. Root cause is the specific weakness that let an unauthenticated attacker on the internet get their first foothold on a bank's DMZ web server.

1. Look at the first request in the access log that returned a 200 with a body, from the external address, using an unusual URL structure. Note the time.

The first successful unusual request occurred at 02:12:33 UTC, when the attacker requested /cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/passwd. The HTTP 200 response with 622 bytes confirms that the server returned the file.

2. Match that request pattern against the findings from your Day 1 assessment. Which finding describes exactly this technique against exactly this software version?

This request matches the Apache HTTP Server 2.4.49 path-traversal vulnerability identified during the Day 1 assessment.

3. Record the finding ID and the CVE. Check your Day 2 work: where did that finding rank after you applied the KEV cross-reference, and where would it have ranked on CVSS alone?

The vulnerability was finding MTB-0002, CVE-2021-41773. It ranked fifth after applying the KEV cross-reference but would have ranked sixth among the validated findings using CVSS alone.

4. Identify the second vulnerability in the chain - the one that took the attacker from the web server account to root. It is also on your Day 1 list.

The second vulnerability was PwnKit, CVE-2021-4034, recorded as finding MTB-0003. It allowed the unprivileged www-data account to use pkexec to obtain a root shell.

5. Note the configuration on MTB-WEB01 that made the first vulnerability exploitable. It is printed in the evidence pack in Section 5.3. The software version alone was not sufficient.

MTB-WEB01 had CGI enabled through ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/, and its root directory was configured with Require all granted. This unsafe configuration allowed traversal outside the intended web directory and command execution through CGI; the root directory should instead use Require all denied.

12.2 Building the incident timeline

Time (UTC)	Event	Evidence source	Confidence
02:08:14	The external address 185.220.101.47 began reconnaissance against MTB-WEB01 using the Nmap Scripting Engine.	Apache access log	Inferred
02:12:33	The attacker successfully exploited Apache path traversal to retrieve /etc/passwd, receiving an HTTP 200 response.	Apache access log	Inferred
02:15:22	The attacker used remote command execution through /bin/sh to create the style.php web shell.	Apache access log and file-system timeline	Confirmed
02:17:40	The attacker began sending commands through the newly created style.php web shell.	Apache access log and recovered style.php file	Confirmed
02:20:47	The www-data account exploited PwnKit through pkexec to open a root session and execute /bin/sh.	Authentication log and matching web-shell activity in the Apache access log	Confirmed
02:23:11	The attacker created the svc-backup account with UID 0, giving it root-equivalent privileges.	Authentication log and file-system timeline	Confirmed
02:24:48	The attacker added an unauthorized SSH key and logged in directly as root from 185.220.101.47.	Authentication log, login history, recovered SSH key, and file-system timeline	Confirmed
02:25:57	The attacker created the executable payload /usr/local/bin/apache-worker.	File-system timeline, root shell history, and volatile process capture	Confirmed
02:26:30	The attacker created /etc/cron.d/apache-logrotate to execute apache-worker as root every five minutes.	File-system timeline, system log, and root shell history	Confirmed
02:34:55	The attacker created an archive of the website's data under /tmp/.ICE-unix, indicating preparation for possible data theft.	File-system timeline, Apache access log, and root shell history	Confirmed
02:41:19	The attacker attempted to erase command-history evidence, but the root history was later recovered.	File-system timeline and recovered root shell history	Confirmed
09:47:12	Security monitoring detected recurring outbound connections from apache-worker to 185.220.101.47 on TCP port 8443.	Security alert, system log, and volatile network captures	Confirmed

12.3 Prevention and monitoring recommendations

- **Patching** - name the packages and the versions to upgrade to, and address why a host built in May was still running software with a publicly known, actively exploited flaw in September.

Upgrade the apache2 package from Apache 2.4.49 to version 2.4.51 or later, which corrects both Apache path-traversal vulnerabilities identified in the assessment. Update policykit-1 to an Ubuntu package confirmed to contain the PwnKit security fix, or upgrade upstream polkit to version 121 or later. The server was built in May but still contained vulnerabilities disclosed and actively exploited years earlier, indicating that the build image was outdated or that patch

verification was not completed. The bank should require authenticated vulnerability scanning before deployment, track KEV-listed findings to closure, and prevent systems with unresolved critical findings from entering production.

- **Configuration** - name the specific Apache directives that made the flaw exploitable and what they should be set to instead.

Remove `ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/` and disable CGI if the application does not require it. If CGI is required, restrict it to the specific approved directory and scripts. Change the root-directory configuration from `Require all granted` to `Require all denied`, then explicitly grant access only to the intended web-content directory. These changes would prevent requests from traversing outside the web directory or executing system commands through CGI.

- **Detection** - at least one recommendation must be an endpoint protection or monitoring improvement that would have caught this faster. The compromise happened at 02:15 and was detected at 09:47. Explain what would have shortened that gap and by roughly how much.

Deploy endpoint monitoring that immediately alerts when an Apache process creates or launches a shell, invokes `pkexec`, writes executable files, or creates PHP files in an upload directory. File-integrity monitoring should watch `/etc/passwd`, `/etc/group`, `/etc/shadow`, all `authorized_keys` files, and `/etc/cron.d/`. Alerts should trigger when a new UID 0 account is created, an SSH key is added, or a root cron task is installed. Outbound firewall rules should also restrict the web server to approved destinations and alert on repeated connections to non-allowlisted addresses and unusual ports such as 8443. These controls could have detected the compromise within minutes of the web shell being created at 02:15 instead of at 09:47, reducing the detection delay from approximately seven and a half hours to less than ten minutes.

12.4 Report

Meridian Trust Bank Forensic Incident Report

Case: MTB-IR-2026-0902

Affected asset: MTB-WEB01

Asset address: 10.50.2.24

System role: DMZ customer portal

Alert time: September 2, 2026, at 09:47 UTC

1. Executive Summary

Meridian Trust Bank's public-facing customer portal was compromised after an external attacker exploited a known web-server weakness. The attacker gained administrative control, created multiple methods of persistent access, and prepared customer data for possible theft. The bank isolated the server at 10:05 UTC, preserved the available evidence, and began investigating the full extent of the compromise. The server should be securely rebuilt, all unauthorized access removed, and stronger patching and monitoring controls implemented before it returns to production.

2. Evidence Handling

The bank isolated MTB-WEB01 through a network access-control rule at 10:05 UTC but intentionally left the host powered on to preserve volatile evidence. Investigators captured running processes at 10:12:41, network connections at 10:13:02, logged-in users and login history at 10:13:20, open network files at 10:13:44, and scheduled tasks at 10:14:05. The disk was acquired at 10:31 UTC after the volatile collection was complete. This order preserved information that would have disappeared if the system had been powered off, including running processes, active connections, open files, and logged-in users.

SHA-256 hashes recorded at acquisition were used to verify the integrity of the recovered artifacts:

- /var/www/html/uploads/style.php
2dfc22e2fb93187b7537d9ffec52ecc94fd6416c84b78e68ff7a025e975c20c
- /usr/local/bin/apache-worker
1ebcce99569f4337f9ee3746b7b095a9f54abfe3036ef06014b1a00ea4d15d4b
- /etc/cron.d/apache-logrotate
d9bc0ee387921dcaedfc87de4a72ec42e45cf268adb2777d5b014375417cb9cc
- /etc/passwd
0243860670744531f70b46cfb844a66eb8ca0de0e4b7b15dff991b3960577295

The SHA-256 verification procedure was also tested in CyberChef. The original evidence block produced the expected hash, while changing one character produced a completely different hash with only three characters remaining in the same positions. This demonstrated that alteration of the evidence would be detectable.

3. Incident Timeline

Time (UTC)	Event	Evidence source	Confidence
02:08:14	External address 185.220.101.47 began reconnaissance using the Nmap Scripting Engine.	Apache access log	Inferred
02:12:33	The attacker successfully exploited Apache path traversal to retrieve /etc/passwd.	Apache access log	Inferred
02:15:22	The attacker used remote command execution to create the style.php web shell.	Apache access log and file-system timeline	Confirmed
02:17:40	The attacker began sending commands through the newly created web shell.	Apache access log and recovered style.php file	Confirmed
02:20:47	The www-data account exploited PwnKit through pkexec to obtain a root session.	Authentication log and matching Apache activity	Confirmed
02:23:11	The attacker created svc-backup with UID 0, giving it root-equivalent privileges.	Authentication log and file-system timeline	Confirmed
02:24:48	The attacker added an unauthorized SSH key and logged in as root from 185.220.101.47.	Authentication log, login history, recovered SSH key, and file-system timeline	Confirmed
02:25:57	The attacker created /usr/local/bin/apache-worker.	File-system timeline, root shell history, and process capture	Confirmed

02:26:30	The attacker created a cron task that executed apache-worker as root every five minutes.	File-system timeline, system log, and root shell history	Confirmed
02:34:55	The attacker archived the website's data under /tmp/.ICE-unix, indicating preparation for possible data theft.	File-system timeline, Apache access log, and root shell history	Confirmed
02:41:19	The attacker attempted to erase command-history evidence.	File-system timeline and recovered root shell history	Confirmed
09:47:12	Monitoring detected recurring outbound connections to 185.220.101.47 on port 8443.	Security alert, system log, and volatile captures	Confirmed

4. Root Cause

The initial compromise occurred at 02:12:33 UTC, when a specially constructed request successfully retrieved /etc/passwd. This activity matched finding MTB-0002, CVE-2021-41773, affecting Apache HTTP Server 2.4.49. The attacker then used the same weakness to execute commands through /bin/sh and create the style.php web shell.

The unsafe configuration on MTB-WEB01 made exploitation possible. CGI was enabled through ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/, and the root directory used Require all granted instead of denying access by default. These settings allowed traversal outside the intended web directory and command execution through CGI.

The attacker later escalated from the unprivileged www-data account to root by exploiting PwnKit, CVE-2021-4034, identified as finding MTB-0003. The authentication log shows uid=33 opening a root session through pkexec and www-data executing /bin/sh as root.

MTB-0002 ranked fifth after threat-intelligence data was applied but would have ranked sixth among the validated findings using severity alone. Both vulnerabilities had been identified before the incident and were listed as actively exploited. The root cause was therefore a failure to remediate known vulnerabilities, combined with an unsafe Apache configuration and insufficient pre-production patch verification.

5. Indicators of Compromise

Type	Indicator (defanged)	Source	What it detects
Network	185[.]220[.]101[.]47	Alert, access log, authentication log, and volatile captures	External attacker address used for exploitation, unauthorized root access, and command-and-control traffic.
Network	185[.]220[.]101[.]47:8443	Alert and network captures	Command-and-control endpoint contacted every five minutes by apache-worker.
File path	/var/www/html/uploads/style.php	File-system timeline and recovered files	Uploaded PHP web shell used to execute commands through web requests.

Type	Indicator (defanged)	Source	What it detects
File path	/usr/local/bin/apache-worker	Process capture, timeline, shell history, and acquisition record	Disguised malicious payload responsible for outbound beaconing.
File hash	2dfc22e2fb93187b7537d9ffec52ecc94fd6416c84b78e68ff7a025e975c20c	Acquisition record	Exact SHA-256 fingerprint of style.php.
File hash	1ebcce99569f4337f9ee3746b7b095a9f54abfe3036ef06014b1a00ea4d15d4b	Acquisition record	Exact SHA-256 fingerprint of apache-worker.
File hash	d9bc0ee387921dcaedfc87de4a72ec42e45cf268adb2777d5b014375417cb9cc	Acquisition record	Exact SHA-256 fingerprint of the malicious cron file.
File hash	0243860670744531f70b46cfb844a66eb8ca0de0e4b7b15dff991b3960577295	Acquisition record	SHA-256 fingerprint of the altered /etc/passwd file.
Account	svc-backup with UID 0	Authentication log, timeline, and root shell history	Unauthorized account with privileges equivalent to root.
Persistence	/etc/cron.d/apache-logrotate	Timeline, cron capture, system log, and shell history	Scheduled task that runs apache-worker as root every five minutes.
Other	SSH key labeled attacker@blackfin	Recovered /root/.ssh/authorized_keys	Unauthorized SSH key providing persistent root access.

6. Recommendations

Immediate containment and recovery

Keep MTB-WEB01 isolated and rebuild it from a trusted, fully patched image rather than attempting to clean it in place. Remove the svc-backup account, unauthorized SSH keys, malicious cron task, apache-worker, style.php, and the staged archive under /tmp/.ICE-unix. Rotate all credentials and keys that were present on the server, review other systems for the listed indicators, and determine whether the staged customer data was transferred outside the environment.

Patching

Upgrade the apache2 package from Apache 2.4.49 to version 2.4.51 or later. Update policykit-1 to an Ubuntu package confirmed to contain the PwnKit fix, or upgrade upstream polkit to version 121 or later. Require authenticated vulnerability scanning before deployment and block systems with unresolved actively exploited vulnerabilities from entering production. Assign actively exploited vulnerabilities an emergency remediation deadline and track them through verification and closure.

Configuration

Disable CGI and remove ScriptAlias /cgi-bin/ /usr/lib/cgi-bin/ if CGI is not required. If it is required, restrict it to approved scripts and directories. Change the root-directory configuration from Require all granted to Require all denied, then explicitly allow access only to the intended web-content directory. Restrict outbound traffic from the web server to approved destinations and required ports.

Detection and monitoring

Deploy endpoint monitoring that immediately alerts when an Apache process launches a shell, invokes pkexec, creates an executable, or writes a PHP file into an upload directory. Implement file-integrity monitoring for /etc/passwd, /etc/group, /etc/shadow, /etc/cron.d/, and all authorized_keys files. Generate immediate alerts for new UID 0 accounts, SSH-key changes, root cron tasks, and recurring connections to non-allowlisted destinations.

These controls could have detected the compromise within minutes of the web shell being created at 02:15 instead of waiting until 09:47. This would reduce the detection delay from approximately seven and a half hours to less than ten minutes and could prevent privilege escalation, persistence, and data staging.

14. Reflection Questions

14.1 Days 1 and 2

1. Why can a vulnerability assessment not stop at the raw scanner output? Give a specific example from this lab of what manual validation changed.

A vulnerability assessment cannot stop at raw scanner output because scanners match patterns and can report vulnerabilities that do not actually affect the installed system. For example, the scanner reported BlueKeep on Windows Server 2019, but manual validation showed that BlueKeep affects older Windows generations. Removing that false positive prevented the team from wasting time remediating a vulnerability that was not present.

2. Give an example from this scan where CVSS score alone would have led you to the wrong priority order, and explain what threat intelligence corrected.

CVSS alone would have placed the Critical vsftpd finding above several lower-scored vulnerabilities. Threat intelligence showed that the Apache path-traversal and PwnKit vulnerabilities were in the KEV catalog with confirmed real-world exploitation, while the vsftpd finding was not. This moved the actively exploited vulnerabilities higher even though some had lower CVSS scores.

3. All three false positives in this scan were in the KEV catalog. Explain why that combination is more dangerous to a security team than a false positive that is not in KEV.

A false positive in KEV appears extremely urgent because the scanner is combining a serious vulnerability with confirmed real-world exploitation. A team that skips validation could spend its limited time patching a system that was never vulnerable while genuine risks remain unresolved. This could also damage the security team's credibility with infrastructure teams when urgent requests repeatedly prove unnecessary.

4. Why is a compensating control still valuable even when it does not fix the underlying vulnerability?

A compensating control reduces the likelihood or impact of exploitation while the permanent fix is delayed. Restricting network access, disabling a vulnerable feature, or increasing monitoring can make the weakness much harder to exploit. Assigning an owner and deadline also prevents the temporary control from quietly becoming permanent.

14.2 Day 3

1. Why does the order you collect evidence in matter, and what specifically would have been lost if the disk had been imaged before the running processes and network connections were captured?

Evidence must be collected in order of volatility because some information disappears much faster than other information. If the system had been powered off or changed while the disk was imaged first, investigators could have

lost the running apache-worker process, its parent and child relationships, the active connection to 185.220.101.47:8443, logged-in users, and open file handles. Those details connected the malicious process directly to the external destination and could not have been fully recovered from the disk alone.

2. How did correlating the host logs with the monitoring alert change or confirm your understanding of what happened?

Correlating the logs with the monitoring alert confirmed that the outbound connection was part of a larger compromise rather than an isolated network anomaly. The combined timestamps showed reconnaissance, Apache exploitation, web-shell creation, privilege escalation, persistence, and repeated command-and-control connections in order. Multiple independent sources supporting the same events made the final explanation more reliable.

3. Why is identifying the root cause more valuable to the bank than simply removing the malicious process and the backdoor account?

Removing the malicious process and backdoor account would only remove two consequences of the attack. If the vulnerable Apache version, unsafe CGI configuration, and weak patching process remained, the attacker could compromise the server again using the same method. Identifying the root cause allows the bank to prevent recurrence and improve the controls that failed across other systems as well.

4. The attacker cleared one shell history file and missed another. What does that tell you about relying on any single evidence source, and how did the timeline let you detect the deletion even though the contents were gone?

The two history files show why an investigation should never depend on one evidence source. Although the mtbadmin history file had been emptied, its zero-byte size and creation timestamp still showed that something unusual happened at 02:41, while the root history preserved the attacker's commands and ended with history -c. By combining file metadata, logs, and recovered history, investigators could identify the deletion attempt even though one file's contents were gone.